



SECURIFY

YOUR SECURITY PARTNER

krishna

Dynamic Analysis Security Test Report

May 28, 2026

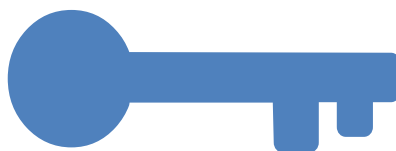


Table of Contents

Table of Contents	2
Scope	3
Application Details	3
User Roles	3
Tools	3
Assessment Limitation	4
Vulnerabilities	5
Summary	5
Detailed Vulnerabilities	6
True Positive	6
Exposed Google API Key for Geocoding API	6
False Positive	8
Open Redirection	8

Scope

The assessment was conducted between May 28, 2026, and May 30, 2026. Testing was performed remotely.

The scope of the assessment was limited to the environments and targets below:

Application Details

Name	URL
abwkjfhahflk	fkjakfnaklf

User Roles

Role	Username
fjakjfkjaf	fkjanjkfnal

Tools

Tool Name	Description
Burp Professional Pro	An advanced proxy for testing web security.
OpenSSL	An open-source package to assess security in transit.
Nmap	A tool used to discover hosts and services on a network.
SQLMap	Python-based CLI tool that identifies SQL injection issues.
Acunetix Pro	An automated scanner to perform authenticated scans on web app / APIs.
cURL Utility	Command line utility to perform HTTP/s requests.

The following components and tests were out of scope for this review:

- Any applications and infrastructure were external to the krishna Web Application.
- In cases where the krishna Web Application had inbound and/or outbound interfaces with another application, the interfaces and communications were considered in scope. All other external elements were excluded.
- Supporting policies, procedures, and processes.
- Social engineering.
- Software development life cycle.

Assessment Limitation

The ever-changing technology landscape and the increasing sophistication of attacks against networked systems are reasons why no entity can truthfully claim to identify all security issues or guarantee the lifetime security of an organization's network and applications. Note that this point-in-time assessment was based on a best-effort basis. It was also performed only in the environment provided by krishna. Thus, changes to the environment may impact the applicability of the results provided herein.

Securify cannot guarantee 100% coverage for any security assessment.

Vulnerabilities

Summary

Below is a summary of the vulnerabilities discovered during the assessment, ranked in order of risk as determined:

Vulnerability	Status	Risk
Exposed Google API Key for Geocoding API	True-Positive	Medium
Open Redirection	False-Positive	

Detailed Vulnerabilities

True Positive

Exposed Google API Key for Geocoding API

Risk: Medium

Description:

An exposed Google API key was identified and validated as active for the Google Maps Geocoding API. While some restrictions were noted for other Google APIs (e.g., YouTube Data API, Google Custom Search API), the key remains publicly accessible and functional for Geocoding requests. This exposure allows unauthorized parties to utilize the key.

Affected URL:

• •

<https://app-staging.silentpush.com/login>

Impact & Likelihood:

Impact: Medium – Unauthorized use of the exposed API key for the Geocoding API could lead to several negative consequences. These include the consumption of the project's API quota, resulting in increased billing costs for the organization. Furthermore, malicious or excessive requests could exhaust the allocated quota, potentially causing service disruption for legitimate users relying on the Geocoding functionality.

Likelihood: High – The Google API key is publicly exposed and was successfully validated against the Google Maps Geocoding API. An attacker can easily discover and reuse this key to make unauthorized requests, making the likelihood of exploitation high.

Steps to Reproduce:

Step 1: Identify the exposed Google API key within the application's client-side code or configuration.

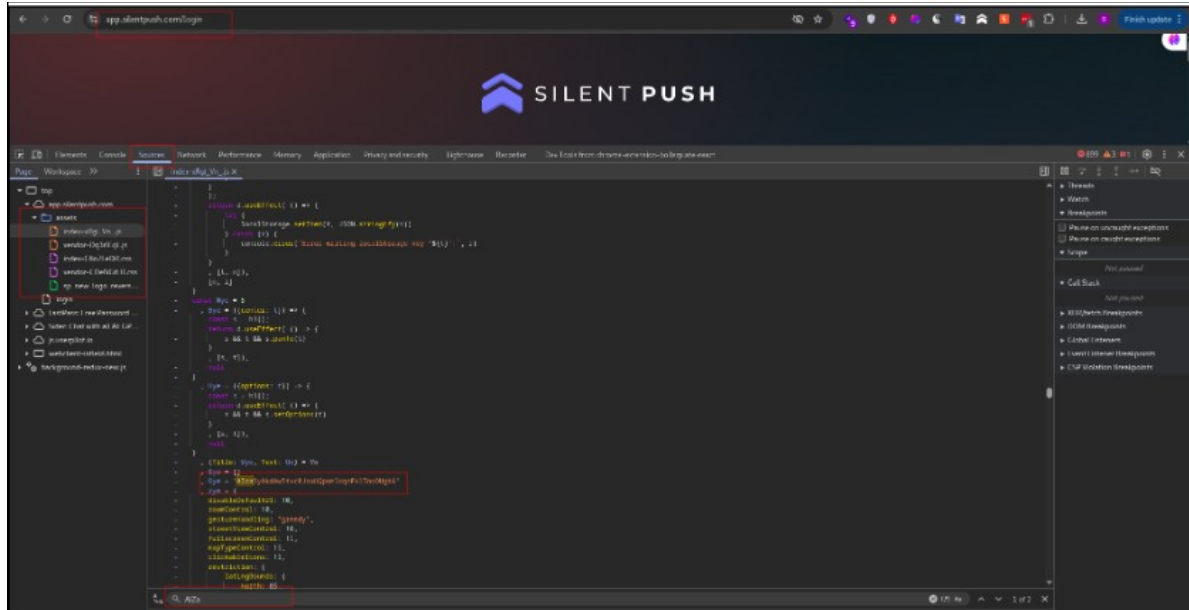


Fig: Google API key exposed in JavaScript file

Step 2: Use the identified API key to send a request to the Google Maps Geocoding API (e.g., 'https://maps.googleapis.com/maps/api/geocode/json?address=1600+Amphitheatre+Parkway,+Mountain+View,+CA&key=YOUR_EXPOSED_API_KEY').

Step 3: Observe a successful response, confirming the key's validity and functionality for the Geocoding API.

Recommendations:

- **API Key Management:** Immediately revoke the exposed API key and generate a new one. Ensure all API keys are stored securely and are not exposed in client-side code, public repositories, or insecure configurations.
- **API Key Restrictions:** Implement strict API key restrictions, including HTTP referer restrictions (if applicable), IP address restrictions, and explicit API service restrictions, to limit the key's functionality only to the necessary services and origins.
- **Quota Monitoring:** Implement robust monitoring and alerting for API key usage and billing to detect and respond to unusual activity promptly.
- **Service Account Usage:** Consider using service accounts with appropriate IAM roles instead of API keys for server-to-server interactions where possible, as service accounts offer more granular control and are less prone to accidental exposure.

References:

- <https://cloud.google.com/docs/authentication/api-keys>
- https://owasp.org/www-project-top-ten/2021/A05_2021-Security_Misconfiguration

[Back to Summary](#)

False Positive

Open Redirection

Description:

The automated scanner identified a potential Open Redirection vulnerability on the `https://app-staging.silentpush.com/api/auth/logout/` endpoint. The scanner reported that user-controlled input supplied through the `next` parameter could potentially lead to redirection to arbitrary external domains. Manual validation was performed to assess this finding. During validation, it was confirmed that the application either sanitizes the `next` parameter input, enforces a whitelist of allowed redirection targets, or restricts redirections to internal application paths only. As a result, the application does not permit redirection to arbitrary external URLs, preventing the exploitation of an Open Redirection vulnerability. This finding is therefore classified as a False Positive.

Affected URL:

• • <https://app-staging.silentpush.com/api/auth/logout/>

Evidence:

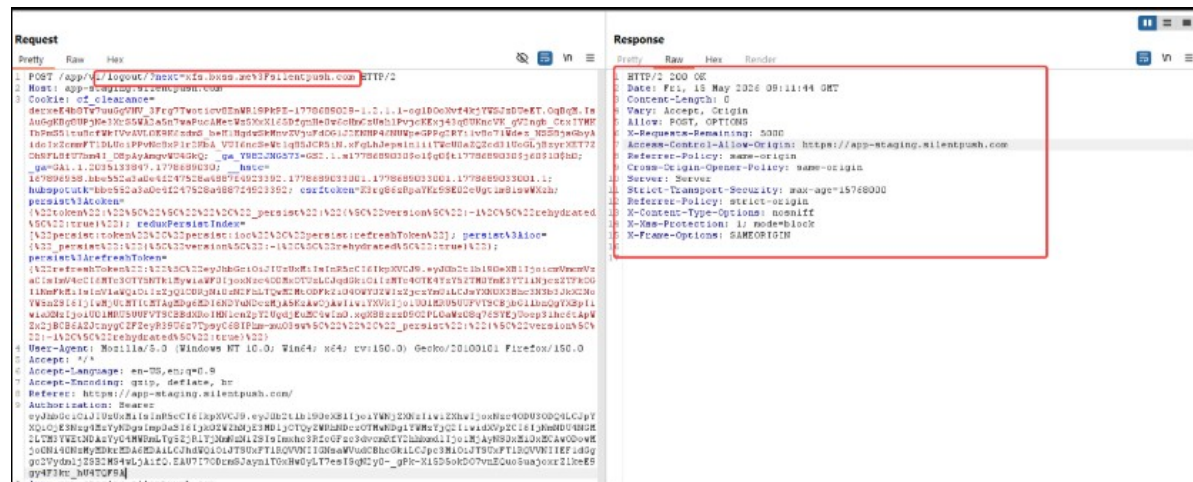


Fig: Logout functionality, with the next parameter is not redirecting to the unintended URL

[Back to Summary](#)